Policy Desk

Win Plan Documentation Pack

UBC Hackathon 2026

Engineering team

Dipak Yadav — Full-stack developer

Utkarsh Lubal — Cybersecurity engineer

Kashif Manzer — Blockchain engineer

Agents get a budget — not a blank check.

Includes win plan, architecture, organizer resources (with full URLs), Streams setup, feature backlog, team split, threat model, and a consolidated links appendix.

Contents

1. Overview (README excerpt)
2. Win plan
3. Architecture
4. Organizer resources
5. Resources (short index)
6. QuickNode Streams
7. Feature backlog
8. Team split
9. Threat model

Appendix A — Organizer & sponsor links

Appendix B — Constants (mint, CAIP-2)

1. Overview (README excerpt)

Policy Desk

Built during UBC Hackathon 2026 *(official hacking began Thu Nov 12, 6:00 PM CST). Prep research / gallery notes lived in a separate private reference project —* ***this repository's git history starts after kickoff.*** *Repo stays* ***private*** *until Devpost submission; flip to public before submit.*

Policy-gated Solana USDC spending for AI agents. Flow judges can see in ~90 seconds:

propose → policy evaluate → human approve → dry-run simulate → Phantom sign → Devnet settle → receipt

Engineering team

GitHub	Name	Role · ownership
@dipak5501	Dipak Yadav	Full-stack developer · product/engineering lead — desk UX, APIs, demo, Devpost
@ubiiii	Utkarsh Lubal	Cybersecurity engineer — threat model, operator gate, adversarial tests
@KashifManzer	Kashif Manzer	Blockchain engineer — Solana USDC settle, Phantom, x402, Streams

Day-by-day ownership: docs/TEAM-SPLIT.md.

Documentation

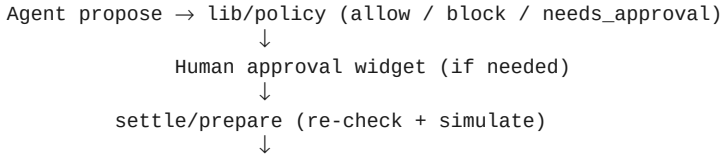
Doc	Purpose
docs/WIN-PLAN.md	Track targets, thesis, 90s story, non-goals, success criteria
docs/ARCHITECTURE.md	propose→…→receipt, x402, trust boundaries, Devnet USDC
docs/ORGANIZER-RESOURCES.md	Sponsor/organizer resources checklist (RPC, mint, Phantom, x402, faucets, Streams)
docs/FEATURE-BACKLOG.md	P0/P1/P2 from gallery best-of, acceptance criteria, owners
docs/TEAM-SPLIT.md	Day 1–5 plan → Fri Nov 20 12:00 PM CST
docs/THREAT-MODEL.md	Honest guarantees + limitations (Utkarsh-owned)
docs/STREAMS.md	QuickNode Streams webhook setup
docs/RESOURCES.md	Compact resource status table

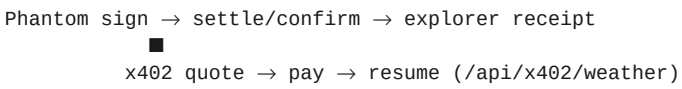
Pitch

AI agents that can pay are useful until they are dangerous. Policy Desk gives an agent a USDC budget on Solana Devnet, then enforces allowlists, caps, and a human approval widget above a threshold. Money only moves when policy says yes — and the desk shows every decision.

Agents get a budget — not a blank check.

Architecture





Full write-up: docs/ARCHITECTURE.md.

Gallery-inspired features (demo-visible)

1. Human approval widgets (SeaPay-style pause)
2. Visible policy decisions + audit log (Agent Guard twin)
3. x402 quote → pay → resume
4. Clear payment state machine
5. First-class receipts with explorer links
6. Dry-run / simulate before broadcast
7. Honest **block before sign** (no fake escrow vault)
8. Gas/fee clarity + insufficient SOL/USDC handling
9. Treasury desk metaphor + posture labels + LIVE ticker
10. Trust strip: Devnet, mint, wallet, allowlist
11. Official resource strip (faucets, Phantom, x402, Circle mint, Streams)
12. QuickNode Streams webhook → LIVE feed (`docs/STREAMS.md`)

Deferred: sponsored/gasless fees, on-chain escrow PDAs, CCTP, NFT attestation, Ollama propose — see docs/FEATURE-BACKLOG.md.

Organizer APIs wired

See docs/ORGANIZER-RESOURCES.md. Core: Solana Devnet RPC, Circle Devnet USDC mint `4zMMC9…`, Phantom connect/sign, x402 V2 weather quote, SOL + Circle faucets. Optional: QuickNode Streams.

Run locally

```
export PATH="$HOME/.nvm/versions/node/v22.18.0/bin:$PATH"  # if needed
cd policy-desk
cp .env.example .env.local
npm install
npm test
npm run build
npm run dev
```

Open http://localhost:3000.

Public demo tunnel (Cloudflare)

```
npm run tunnel:refresh
cat .tunnel-url
```

Wallet / faucet

1. Phantom → **Devnet**
2. SOL — https://faucet.solana.com
3. USDC — https://faucet.circle.com (Solana / Devnet / USDC)

Demo script (~60–90s)

1. Open Policy Desk → Connect Phantom (Devnet) → show trust strip + posture.
2. **Run 90s demo**:

- Non-allowlisted merchant → **blocked** (no tx).
- Above-threshold x402 → **human approval** widget → Approve.
- Simulate → Phantom sign → **settled** receipt + explorer.

3. One-liner: “Agents get a budget — not a blank check.”

Threat model

See docs/THREAT-MODEL.md for enforced guarantees and honest limitations.

Eligibility note

UBC Hackathon 2026 requires projects built during the hackathon. This app was scaffolded and committed in the allowed window. Do **not** submit older pre-kickoff prep repositories as the Devpost artifact.

Win plan — Policy Desk (UBC Hackathon 2026)

Submit: Fri Nov 20, 12:00 PM CST · **Artifact:** this repo only (`policy-desk`) · **Repo:** private until Devpost flip
Eligibility: Built during the official hacking window. Do **not** submit prep / `guarded-agent-treasury` as the Devpost project.

Track targets (select on Devpost)

Priority	Track / bounty	Why we fit
Primary	**Agentic Payments and AI**	Policy-gated agent USDC spend + x402 quote→pay→resume
Chain	**Best use of Solana**	Devnet USDC, Phantom sign, TransferChecked settle, explorer receipts
Bounty	**QuickNode Streams** (if P0 time allows)	Webhook → LIVE audit ticker beside policy decisions
Auto	Official UBC Winner	Clean demo + eligibility + honest craft

Thesis

AI agents that can pay are useful until they are dangerous. **Policy Desk** gives an agent a Solana Devnet USDC budget, then enforces allowlists, caps, and a human approval gate above threshold. Money only moves when policy says yes — and the desk shows every decision.

One-liner for judges: **Agents get a budget — not a blank check.**

90-second judge story

1. **Connect** Phantom (Devnet) → trust strip: RPC cluster, Circle mint `4zMMC9…`, wallet, allowlist posture.
2. **Block** — non-allowlisted merchant propose → **blocked** (no transaction materializes).
3. **Approve** — above-threshold x402 weather → human approval widget → operator Approve.
4. **Settle** — dry-run simulate → Phantom sign → Devnet settle → receipt + explorer link.
5. **Close** — “The model proposes. Policy decides. Humans co-sign the big ones.” (Optional: Streams hit on LIVE ticker.)

Killer demo path (one path only)

```
propose → policy evaluate → human approve (if needed)
        → simulate → Phantom sign → settle → receipt
        ■ x402 weather quote → pay → resume
```

Everything else is support for this path. Do not fork the demo into a second product narrative.

What NOT to build (eligibility + focus)

Skip	Why
Arc, Circle Agent Wallets (no Solana), CCTP bridges	Off-track / time sink
Gemini, ElevenLabs, Grok as core UX	Distracts from Solana + agentic payments
Full Agent Kit plugin surface	Scope explosion
On-chain Anchor escrow / PDA vault	Honest MVP = **block before sign**, not fake custody

Skip	Why
Sponsored/gasless fee payer	P2; Phantom + faucet path is enough
NFT attestation mints	P2 polish only after P0 locked
Ollama / live LLM propose	Scenario packs are deterministic for judges
Submitting prep GAT repo	Eligibility risk — **policy-desk only**

Success criteria

Gate	Done when
Demo reliability	Cold-start → block + approve + settle + receipt in ≤90s, twice in a row
Policy honesty	Non-allowlisted spend never reaches Phantom; caps + threshold visible
Chain truth	Settled rows have Solana explorer links on Devnet USDC mint
x402	Weather quote → pay → resume works under and above approval threshold
Security story	`THREAT-MODEL.md` lists guarantees **and** limitations; adversarial tests green
Eligibility	Git history starts in hackathon window; Devpost points at this private→public repo
Submit package	README + docs, 2–3 min video, Devpost writeup, live tunnel or deploy URL

Engineering team (RACI)

Professionals by discipline — full-stack, cybersecurity, and blockchain — with explicit ownership (no invented employers, years, or certs).

Person	Role	Owns
Dipak Yadav (@dipak5501)	Full-stack developer · product/engineering lead	Desk UX, API routes, demo script, Devpost, integration glue
Utkarsh Lubal (@ubiiii)	Cybersecurity engineer	Threat model, operator gate, adversarial tests, audit integrity
Kashif Manzer (@KashifManzer)	Blockchain engineer	Solana RPC/USDC, Phantom settle, x402 exact verify, Streams

Review gates: Kashif signs off settle/x402; Utkarsh signs off trust boundaries; Dipak owns merge + judge path.

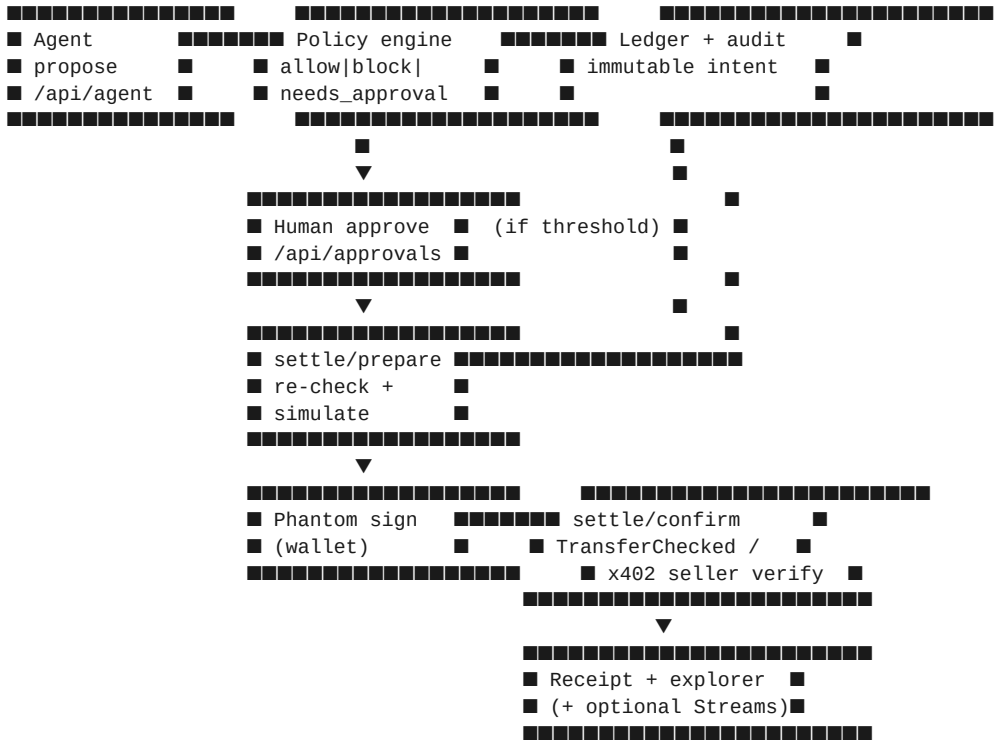
Day map (→ Fri Nov 20 noon CST)

See TEAM-SPLIT.md. Feature order: FEATURE-BACKLOG.md.

Architecture — Policy Desk

Policy-gated Solana Devnet USDC spending for AI agents. Settlement is **non-custodial**: Phantom holds keys; the desk decides whether a spend may be prepared and confirmed.

End-to-end flow



State machine (payment)

`proposed` → `blocked` | `pending_approval` | `approved` | `ready_to_sign` → `confirming` → `settled` (plus `rejected` / failed paths). UI `PaymentProgress` mirrors these states for judges.

x402 branch

```
GET/POST /api/x402/weather
  → 402 + PAYMENT-* challenge (quote)
  → policy + prepare + Phantom sign
  → seller verifies exact amount/mint/payTo/transfer shape
  → resume with resource body
```

CAIP-2 network: `solana:EtWTRABZaYq6iMfeYKouRu166VU2xqa1` (Devnet). Mint: Circle Devnet USDC `4zMMC9srt5Ri5X14GAgXhaHii3GnPAEERYPJgZJDncDU`.

Module map

Layer	Path	Responsibility
Desk UI	`app/page.tsx`, `components/*`	Connect wallet, scenarios, approval widget, progress, receipts, resource strip
Propose	`app/api/agent/propose`	Scenario/custom spend → `reviewSpend` → ledger entry

Layer	Path	Responsibility
Policy	`lib/policy/*`	Caps, allowlists, mint, pause, approval threshold, regime labels
Approvals	`app/api/approvals/[id]`	Operator-gated approve/reject
Settle	`app/api/settle/prepare`, `confirm`	Re-check policy, simulate, bind prepareId; verify + broadcast
Solana	`lib/solana/*`	Connection, balances, TransferChecked build/validate
x402	`lib/x402/*`, `app/api/x402/weather`	Quote, seller self-facilitate, resume
Ledger	`lib/ledger/store`	Durable `.data/ledger.json` + status transitions
Audit	`lib/security/audit`	Append-only `.data/audit.jsonl`
Streams	`app/api/streams/webhook`	Optional QuickNode ingest → LIVE ticker
Operator	`lib/security/operator`	Shared-secret gate (`OPERATOR_TOKEN`)

Trust boundaries

```
[Untrusted]
  Browser UI · agent/scenario text · seller HTTP body · Streams webhook JSON
        ■
        ▼
[Trusted desk server]
  reviewSpend · ledger intentHash · prepare re-check · confirm decode
  Operator token required for approve/reject
        ■
        ▼
[Wallet boundary]
  Phantom signs only the prepared transaction bytes
  Desk never holds user keys
        ■
        ▼
[Solana Devnet]
  SPL USDC TransferChecked / x402 exact settle
  Explorer = settlement truth for receipts
```

Boundary	Rule
Model → policy	Scenario/agent text never sets caps, mint, or allowlists
Browser → approvals	`x-operator-token` / Bearer must match `OPERATOR_TOKEN` (fail closed if unset)
Browser → settle	Prepare re-runs policy + destination binding; confirm validates TransferChecked
Seller → desk	x402 seller checks amount, mint, payTo, signed transfer shape
Webhook → ledger	Streams verifies shared secret when configured; otherwise acknowledge-only
Config → cluster	Devnet lock — refuse mainnet RPC/cluster configuration

Devnet USDC

Item	Value
Cluster	`devnet` (`NEXT_PUBLIC_SOLANA_CLUSTER`)
RPC	`SOLANA_RPC_URL` (prefer private QuickNode; fallback public Devnet)
Mint	`4zMMC9srt5Ri5X14GAgXhaHii3GnPAEERYPJgZJDncDU`

Item	Value
Decimals	6 (base units: `1_000_000` = $1)
Wallet	Phantom · user switches network to Devnet
Faucets	SOL: faucet.solana.com · USDC: faucet.circle.com

Design choices (production-minded prototype)

1. **Block before sign** — no Anchor escrow PDA in this build; honesty over theater.
2. **Immutable intent** — payee / amount / mint / resource bound at create (`intentHash`).
3. **Double policy check** — propose and prepare both call `reviewSpend`.
4. **Budget reservation** — pending / approved / ready_to_sign / confirming / settled count toward daily cap.
5. **Single-process ledger** — fine for hackathon demo; not multi-region HA (documented in threat model).

Related docs

- WIN-PLAN.md — demo path and non-goals
- THREAT-MODEL.md — guarantees and limitations
- STREAMS.md — optional QuickNode bounty wiring
- ORGANIZER-RESOURCES.md — sponsor links and status

Organizer / sponsor resources — checklist

Real UBC Hackathon 2026 / sponsor resources only. **No invented APIs.** Owners: Dipak (product wiring) · Kashif (chain/RPC/Streams) · Utkarsh (webhook secret / abuse review).

Resource	Link	Wired in policy-desk	Owner	Status
Solana Devnet RPC	api.devnet.solana.com / private QuickNode HTTP URL via `SOLANA_RPC_URL`	`lib/solana/connection.ts`, `.env.example`	Kashif	**Wired** — prefer private endpoint for demos
Circle Devnet USDC mint	USDC contract addresses · `4zMMC9srt5Ri5X14GAgXhaHii3GnPAEERYPJgZJDncDU`	Policy allowlist, balances, settle, trust strip	Kashif	**Wired**
Phantom wallet	phantom.app/download	Connect + sign (`WalletProvider`, settle path)	Dipak + Kashif	**Wired** — judges must switch to Devnet
x402 on Solana (V2)	Agentic payments / x402 · CAIP-2 `solana:EtWTRABZaYq6iMfeYKouRu166VU2xqa1`	`/api/x402/weather` quote → pay → resume	Kashif	**Wired**
SOL faucet	faucet.solana.com	`ResourceStrip` + README	Dipak	**Linked**
Circle USDC faucet	faucet.circle.com · Solana / Devnet / USDC	`ResourceStrip` + README	Dipak	**Linked**
QuickNode Streams	Streams quickstart · Solana program data guide	`POST/GET /api/streams/webhook` + LIVE ticker	Kashif · secret review Utkarsh	**Wired (optional bounty)** — configure stream + `QUICKNODE_STREAM_WEBHOOK_SECRET`; see STREAMS.md
Circle docs (stablecoins)	developers.circle.com	Mint constant + UI note	Kashif	**Referenced**
Solana explorer (Devnet)	Receipt links from settle confirm	Settled ledger / UI receipts	Kashif	**Wired**

UI surface

`components/ResourceStrip.tsx` exposes faucet, Phantom, x402, mint, and Streams links on the desk.

SKIP (per track / scope)

Skip	Reason
Arc	Not Solana demo path
Circle Agent Wallets	No Solana
CCTP cross-chain	Out of killer demo path
Gemini / ElevenLabs / Grok as core	Not needed for Solana + agentic payments story
Full Agent Kit plugin matrix	Scope

Pre-judge faucet checklist

1. Phantom → **Devnet**

2. SOL ≥ ~0.02 from faucet.solana.com
3. USDC ≥ ~0.60 from faucet.circle.com (Solana / Devnet / USDC)
4. Confirm trust strip mint matches `4zMMC9srt5Ri5X14GAgXhaHii3GnPAEERYPJgZJDncDU`
5. If claiming Streams bounty: webhook secret set + one LIVE `stream` event visible (STREAMS.md)

Companion docs

- Compact status table (legacy): RESOURCES.md
- Streams setup: STREAMS.md

Resources (short index)

Full integration checklist with owners + status: **ORGANIZER-RESOURCES.md**. Streams bounty setup: **STREAMS.md**. Win strategy: **WIN-PLAN.md**.

Quick links (official)

Need	URL
SOL faucet	https://faucet.solana.com
USDC faucet (Circle)	https://faucet.circle.com/
Phantom	https://phantom.app/download
x402 on Solana	https://solana.com/docs/payments/agentic-payments/x402
Circle USDC addresses	https://developers.circle.com/stablecoins/usdc-contract-addresses
QuickNode Streams	https://www.quicknode.com/docs/streams/quickstart
UBC Devpost	https://ubc-hackathon-2026.devpost.com/

Devnet USDC mint: `4zMMC9srt5Ri5X14GAgXhaHii3GnPAEERYPJgZJDncDU` **x402 CAIP-2:** `solana:EtWTRABZaYq6iMfeYKouRu166VU2xqa1`

QuickNode Streams (optional UBC $500 bounty)

Streams feeds Solana Devnet USDC activity into Policy Desk so judges see an **on-chain audit trail** next to policy decisions.

What shipped

1. `POST /api/streams/webhook` — verifies `QUICKNODE_STREAM_WEBHOOK_SECRET`, appends events to the durable ledger feed.
2. `GET /api/streams/webhook` — returns recent stream events for the LIVE ticker.
3. Desk **LIVE** ticker shows `stream` hits alongside blocked / settled ledger rows.

Configure

1. Create a QuickNode account + **Solana Devnet** endpoint (also set `SOLANA_RPC_URL` to that HTTP URL).
2. Create a Stream filtered to Token Program transfers involving:
   - Devnet USDC mint `4zMMC9srt5Ri5X14GAgXhaHii3GnPAEERYPJgZJDncDU`
   - Your treasury wallet and/or demo payee
3. Destination: HTTPS webhook → `https://<your-tunnel-or-deploy>/api/streams/webhook`
4. Set a shared secret:

```
QUICKNODE_STREAM_WEBHOOK_SECRET=replace-me
# Accepted headers: x-qn-signature | x-webhook-secret | Authorization: Bearer …
```

Field	Value
Stream id	_(fill after create)_
Network	Solana Devnet
Filter	USDC mint + treasury/payee ATAs
Webhook	`/api/streams/webhook`

Local test without QuickNode

```
curl -X POST http://localhost:3000/api/streams/webhook \
  -H 'Content-Type: application/json' \
  -H 'x-webhook-secret: replace-me' \
  -d '{"signature":"DemoSig1111111111111111111111111111111111111111","note":"manual"}'
```

Refresh the desk — the LIVE ticker should show a `stream` item.

Links (organizer / sponsor)

- Streams quickstart
- Stream Solana program data

Feature backlog — gallery best-of → Policy Desk

Priorities distilled from MBC 2025 gallery synthesis (`guarded-agent-treasury/docs/MBC-2025-GALLERY-NOTES.md` §5) and what already ships in this repo. **P0** = demo-critical for Fri Nov 20 · **P1** = high leverage if P0 green · **P2** = only after polish buffer.

Owners: **Dipak** (full-stack / product) · **Utkarsh** (cybersecurity) · **Kashif** (blockchain).

P0 — must ship for the killer path

ID	Feature	Gallery source	Acceptance criteria	Owner	Status
P0-1	Human approval interrupt widget	SeaPay	Above-threshold spend pauses at widget; Approve/Reject via operator token; no Phantom prompt before Approve	Dipak · gate Utkarsh	**In app** — harden copy + failure UX
P0-2	Visible policy decisions + audit log	Agent Guard	Every propose shows allow/block/needs_approval + reason; transitions append audit; desk shows decision text judges can read	Dipak · Utkarsh	**In app** — keep ledger/audit durable across demo restarts
P0-3	x402 quote → pay → resume	Instant Markets, Quarry, SeaPay	`/api/x402/weather` returns challenge; under-threshold auto path and above-threshold approval path both resume with body after settle	Kashif · Dipak UI	**In app** — exact seller verify regression tests
P0-4	Receipt + explorer link	PolyHedge, Quarry	Settled row shows signature, amount, payee, Devnet explorer URL; copyable	Dipak · Kashif	**In app** — verify cold-path
P0-5	Clear payment state machine	Gallery UX pattern	UI steps match propose→…→settled; blocked never offers Sign	Dipak	**In app** — `PaymentProgress`
P0-6	Dry-run / simulate before broadcast	Agent Guard, PolyHedge	Prepare simulates; insufficient SOL/USDC surfaces before sign; dry-run scenario does not spend	Kashif · Dipak	**In app** — judge-script dry-run button reliable
P0-7	Honest block-before-sign	Aegis / our thesis	Non-allowlisted merchant **never** builds a signable tx; no fake escrow vault claimed	Utkarsh · Kashif	**In app** — adversarial tests must stay green
P0-8	Trust strip + organizer resources	Density/trust cues	Devnet, mint `4zMMC9…`, wallet, allowlist posture + ResourceStrip links live	Dipak	**In app**

ID	Feature	Gallery source	Acceptance criteria	Owner	Status
P0-9	90s demo script reliability	Win plan	Blocked + approval + settle path runs twice cold without manual ledger wipe	All	**Active** — Day 1–2 DoD
P0-10	Streams LIVE feed *(if time)*	QuickNode bounty	Webhook auth + ticker shows `stream` beside ledger; documented in STREAMS.md	Kashif · Utkarsh secret	**Wired** — configure live stream or drop bounty claim

---

P1 — high leverage after P0

ID	Feature	Gallery source	Acceptance criteria	Owner	Status
P1-1	Fee / balance clarity	Gasless Hub (friction lesson)	Desk shows SOL + USDC; clear error when either insufficient	Dipak · Kashif	Partial
P1-2	Treasury posture labels	FRCT	Defensive / Neutral / Aggressive (or equivalent) tied to policy regime	Dipak	Partial (`regime`)
P1-3	Stronger adversarial suite	Security craft	Signature-only confirm rejected; wrong mint/over-cap/non-allowlist covered in CI `npm test`	Utkarsh	Partial — expand
P1-4	Private Devnet RPC	Demo reliability	QuickNode (or equiv) URL in `.env.local`; public RPC only fallback	Kashif	Checklist
P1-5	Public tunnel / deploy URL	Judging	`npm run tunnel:refresh` or hosted URL stable for video + Devpost	Dipak	Ops
P1-6	Pitch video 2–3 min	PITCH pattern	Problem → path → live clip → threat honesty → close	Dipak (cut) · all on camera path	Not started

---

P2 — defer unless ahead of schedule

ID	Feature	Gallery source	Why deferred
P2-1	Sponsored / gasless fees	Gasless Hub, Instant Markets	Not required; faucet path sufficient
P2-2	On-chain escrow PDAs	SolMail, Trust Pay	Conflicts with honest block-before-sign MVP
P2-3	NFT / attestation receipt mint	PolyHedge, Quarry	Nice shareable; not needed for settle proof
P2-4	Chat-first proposal UX	SeaPay, SolMail	Scenario cards already tell the story
P2-5	CCTP / cross-chain USDC	FRCT, HyperSphere	Off killer path; eligibility noise
P2-6	Ollama live propose	—	Non-deterministic demos
P2-7	Agent marketplace	agent rank	Out of scope

Definition of “gallery P0 done”

Judges can, without coaching beyond the 90s script:

1. See a **block** with no wallet popup.
2. See a **human approval** interrupt, then Approve.
3. See **simulate** → **sign** → **settle** → **explorer receipt**.
4. Optionally see an **x402 resume** and a **Streams** tick.

Anything that does not serve that sequence is not P0.

Team split — Day 1–5 (→ Fri Nov 20, 12:00 PM CST)

Three working engineers with complementary specialties shipping a production-minded prototype. Clear RACI, parallel streams, daily DoD.

Roster

Engineer	GitHub	Discipline	Accountable for
Dipak Yadav	@dipak5501	Full-stack developer · product/engineering lead	Desk UX, API glue, demo script, Devpost, merge cadence, judge path
Utkarsh Lubal	@ubiiii	Cybersecurity engineer	Threat model, operator auth, adversarial tests, audit integrity, public-demo hardening
Kashif Manzer	@KashifManzer	Blockchain engineer	Solana Devnet USDC, Phantom settle, x402 exact verify, RPC/Streams, explorer receipts

RACI shorthand: Dipak = **A** on product demo · Kashif = **A** on chain settle · Utkarsh = **A** on security claims · each is **C** on the others' P0 merges.

Calendar context: hacking window open; **hard stop Fri Nov 20 12:00 PM CST**. Days below are build days with a submit morning buffer.

Day	Date (2026)	Theme
1	Sat Nov 15	Lock killer path + P0 gaps
2	Sun Nov 16	Chain + x402 harden
3	Mon Nov 17	Security pass + adversarial
4	Tue Nov 18	Streams (if claiming) + polish
5	Wed Nov 19 → Thu Nov 20 AM	Pitch, video, Devpost, submit by noon CST Fri

(If the team works Fri Nov 14, treat it as Day 1 early start; do not slip Day 5.)

Day 1 — Lock the killer path

Parallel

Stream	Owner	Work
Full-stack	Dipak	Cold-run 90s script; fix UI blockers on approve/progress/receipt; ResourceStrip + trust strip accurate
Blockchain	Kashif	Verify Devnet mint, balances API, prepare simulate, confirm TransferChecked on happy path
Security	Utkarsh	Draft/expand THREAT-MODEL.md; confirm operator fail-closed; list attack cases for Day 3

Handoffs

- Kashif → Dipak: prepare/confirm error shapes for UI.
- Utkarsh → both: "never claim X" list for README/pitch.

DoD

- [ ] Blocked merchant demo: no Phantom prompt.
- [ ] Approval demo reaches Approve widget.
- [ ] One successful settle + explorer link on Devnet.
- [ ] `npm test` + `npm run build` green.

Day 2 — Solana + x402 reliability

Parallel

Stream	Owner	Work
Blockchain	Kashif	x402 weather under + above threshold; seller exact verify; fee/USDC insufficient paths
Full-stack	Dipak	Wire failure copy; guided “Run 90s demo” stable; tunnel script documented
Security	Utkarsh	Review settle/confirm for signature-only / intent mutation gaps; ticket any P0 holes

Handoffs

- Kashif → Dipak: x402 resume payload contract for UI.
- Utkarsh → Kashif: must-fix confirm cases before Day 3 suite.

DoD

- [ ] x402 quote → pay → resume twice cold.
- [ ] Above-threshold x402 requires approval.
- [ ] Insufficient SOL/USDC fails before sign with clear UI.
- [ ] No mainnet config possible (devnet lock holds).

Day 3 — Security engineering day

Parallel

Stream	Owner	Work
Security	Utkarsh	Expand `lib/security/adversarial.test.ts`; finalize THREAT-MODEL guarantees vs limitations; webhook secret guidance
Blockchain	Kashif	Implement Utkarsh’s confirm/prepare fixes; private RPC in `.env.local`
Full-stack	Dipak	Surface audit/decision text for judges; remove any overclaim copy

Handoffs

- Utkarsh → Kashif: failing tests first (red), then green together.
- Dipak → Utkarsh: public tunnel threat notes for threat model “limitations”.

DoD

- [ ] Adversarial suite covers: non-allowlist block, wrong mint, over cap, signature-only reject.
- [ ] THREAT-MODEL.md reviewed by all three.
- [ ] Operator token rotation note for public demo.

Day 4 — Streams (optional bounty) + polish

Parallel

Stream	Owner	Work
Blockchain	Kashif	Configure QuickNode Stream → `/api/streams/webhook`; prove LIVE `stream` tick **or** formally drop bounty claim
Full-stack	Dipak	Visual polish only on the killer path; backup screen recording
Security	Utkarsh	Webhook auth review; rate/abuse notes; final "honest guarantees" pass on pitch kit language

Handoffs

- Kashif → Dipak: one Streams screenshot/GIF for Devpost.
- If Streams slips: Dipak removes bounty claim from pitch; no half-claims.

DoD

- [ ] Either Streams live end-to-end **or** bounty deselected everywhere.
- [ ] Full 90s path recorded as backup.
- [ ] Docs links from README all resolve.

Day 5 — Ship package (Wed Nov 19 → Fri Nov 20 noon CST)

Parallel

Stream	Owner	Work
Lead	Dipak	Devpost writeup, video edit, repo public flip before submit, final README, live URL
Blockchain	Kashif	Pre-flight faucet balances; RPC health; settle smoke 30 min before judging/submit
Security	Utkarsh	Final threat-model quote for Devpost; rotate demo operator token if URL is public

Submit checklist

- [ ] Devpost artifact = **policy-desk only** (not prep GAT).
- [ ] Tracks: Agentic Payments and AI + Best use of Solana (+ Streams only if live).
- [ ] Video ≤3 min covering block → approve → settle → receipt.
- [ ] Repo public (or per organizer rule) at submit time.
- [ ] Hard stop: **Fri Nov 20, 12:00 PM CST**.

DoD

- [ ] Submission uploaded and confirmed.
- [ ] Team handles listed accurately (Dipak / Utkarsh / Kashif + GitHubs).
- [ ] One spare laptop/browser with Phantom Devnet funded.

What each person does next (immediate)

Engineer	Next actions
Dipak	Own Day 1 cold 90s runs; close UI gaps on approval → receipt; keep docs ↔ product aligned; schedule Devpost draft

Engineer	Next actions
Utkarsh	Own THREAT-MODEL.md; enumerate adversarial cases; verify operator fail-closed on approvals API
Kashif	Own Devnet settle + x402 exact path; set private RPC; Streams config decision by end of Day 4

Communication

- Merge through Dipak unless hotfix on chain/security.
- No scope adds without cutting something from FEATURE-BACKLOG.md P0.
- Overclaim ban: if it is not enforced in code + tests, it is not in the pitch.

Threat model — Policy Desk

Owner: Utkarsh Lubal (@ubiiii), cybersecurity engineer **Reviewers:** Dipak Yadav (product/engineering), Kashif Manzer (blockchain) **Scope:** Solana **Devnet** hackathon prototype (UBC 2026). Not a production custody product. **Audit status:** No third-party security audit has been performed on this repository.

Assets

Asset	Why it matters
USDC in the connected Phantom wallet	Devnet funds the human controls; desk must not trick-sign drains
Daily / per-tx spend budget	Prevents agent overspend within the desk session
Allowlisted payees & resources	Stops arbitrary merchant drains
Ledger + audit trail	Demo integrity and post-hoc review
Operator token	Gates human approve / reject
Streams webhook secret	Prevents forged LIVE feed events when bounty path is enabled

Trust boundaries

```
[Untrusted] Browser UI, agent/scenario text, seller HTTP, webhook JSON
      ■
      ▼
[Server policy + ledger]  reviewSpend → immutable intent → prepare/confirm
      ■
      ▼
[Wallet] Phantom signs only what prepare built
      ■
      ▼
[Solana Devnet] SPL USDC / x402 seller self-facilitate
```

Boundary	Rule
Model → policy	Scenario/agent text never sets caps, mint, or allowlists
Browser → approvals	`x-operator-token` / Bearer must match `OPERATOR_TOKEN` (fail closed if unset)
Browser → settle	Prepare re-checks policy + destination; confirm validates TransferChecked
Seller → desk	x402 seller verifies amount, mint, payTo, and signed transfer shape
Webhook → ledger	Streams verifies shared secret **when configured**; otherwise acknowledge-only
Config → network	Cluster/RPC guards refuse mainnet configuration

Enforced guarantees (this build)

1. **Policy before materialization** — `reviewSpend` on propose and again on prepare; blocked spends never get a transaction.
2. **Immutable payment intent** — `payee`, `amount`, `mint`, and `resource` cannot be patched after create (`intentHash`).
3. **Destination binding at settle** — payee must be allowlisted **or** equal the spending wallet on an allowlisted resource (pay-self demo).

4. **Signed tx matches intent** — confirm decodes TransferChecked (mint, amount, ATAs, authority) before treating settle as valid; signature-only confirm is rejected.
5. **Human gate above threshold** — `needs_approval` requires operator Approve before prepare/sign.
6. **Budget reservation** — pending / approved / ready_to_sign / confirming / settled count toward the daily cap.
7. **Replay resistance (desk-level)** — settled entries cannot be settled again; prepare binds `prepareId` + expiry.
8. **Devnet lock** — refuse mainnet cluster/RPC configuration.
9. **Audit log** — status transitions append to durable audit trail (best-effort `.data/audit.jsonl`).

Honest limitations

Limitation	Why
Operator token is a shared secret	Demo auth — not SSO, WebAuthn, or wallet-signed approvals
In-process / file ledger	Not multi-region HA; wiping `.data` loses history; not a bank ledger
No on-chain policy program	Caps live in the Next.js process, not an Anchor vault
Safety model is block-before-sign	No escrow PDA locks funds; honesty over custody theater
x402 seller is a local demo facilitator	Not a hosted facilitator / compliance network
Streams webhook	Secret must be set for untrusted internet exposure; optional bounty path
Phantom UX	User can still sign unrelated txs outside this desk
Public tunnel / deploy URL	Anyone with the URL + operator token can hit approval APIs — rotate token for public demos
RPC / faucet availability	External dependency; dry-run still shows policy path if chain is down

Adversarial coverage

Primary suites: `lib/security/adversarial.test.ts`, policy review tests, TransferChecked validation tests.

Expected red-team cases (owners: Utkarsh design · Kashif chain fixes · Dipak UI honesty):

- Signature-only confirm rejection
- Wrong-mint / over-cap / non-allowlisted propose blocks
- Destination allowlist enforcement
- TransferChecked amount/payee mismatch detection
- Approval without valid operator token rejected

What we will not claim in pitch

- Production-grade custody, MPC, or hardware-enforced agent keys
- Formal verification or external audit
- Mainnet readiness
- That policy lives on-chain in this MVP

Related

- ARCHITECTURE.md — flow and boundaries
- FEATURE-BACKLOG.md — P1 adversarial expansion
- STREAMS.md — webhook secret configuration

Appendix A — Organizer & sponsor links

Every official / sponsor URL referenced in Policy Desk docs, ResourceStrip, and config. Copy-paste friendly. Links are clickable in PDF viewers that support URI annotations.

Name	Full URL
Solana Devnet RPC	https://api.devnet.solana.com
SOL faucet	https://faucet.solana.com
Circle USDC faucet	https://faucet.circle.com/
Phantom wallet download	https://phantom.app/download
x402 on Solana (agentic payments)	https://solana.com/docs/payments/agentic-payments/x402
Circle USDC contract addresses	https://developers.circle.com/stablecoins/usdc-contract-addresses
QuickNode Streams quickstart	https://www.quicknode.com/docs/streams/quickstart
QuickNode: Stream Solana program data	https://www.quicknode.com/guides/quicknode-products/streams/how-to-stream-solana-program-data
UBC Hackathon 2026 Devpost	https://ubc-hackathon-2026.devpost.com/
Solana Explorer (tx template)	https://explorer.solana.com/tx/<signature>?cluster=devnet
Solana Explorer (address template)	https://explorer.solana.com/address/<address>?cluster=devnet
Local desk (dev)	http://localhost:3000
GitHub — Dipak Yadav	https://github.com/dipak5501
GitHub — Utkarsh Lubal	https://github.com/ubiiii
GitHub — Kashif Manzer	https://github.com/KashifManzer
GitHub repo — policy-desk	https://github.com/dipak5501/policy-desk

Also keep these env / config pointers handy (not public URLs): `SOLANA_RPC_URL` (prefer private QuickNode HTTP), `OPERATOR_TOKEN`, `QUICKNODE_STREAM_WEBHOOK_SECRET`, webhook path `/api/streams/webhook`.

Appendix B — Constants

Constant	Value
Devnet USDC mint	`4zMMC9srt5Ri5X14GAgXhaHii3GnPAEERYPJgZJDncDU`
x402 CAIP-2 (Solana Devnet)	`solana:EtWTRABZaYq6iMfeYKouRu166VU2xqa1`